

SECURITY ASSESSMENT REPORT

Home Gateway Audit — Tenda Router Infrastructure

Prepared: May 22, 2026 | Classification: Internal / Confidential

1. EXECUTIVE SUMMARY

A comprehensive local security audit was performed on the primary gateway device at IP address **192.168.8.145**. The diagnostic assessment utilised automated signature scanners and metadata header analysis to evaluate the device's exposure profile.

The assessment identified a **critical access control vulnerability** that allows unauthenticated access to system configuration data. Remediation actions must be taken immediately to prevent unauthorised administrative control of the local network segment.

2. SUMMARY OF FINDINGS

Device / IP	Risk Level	Primary Findings
192.168.8.145 (Tenda F3 V2.0)	HIGH / CRITICAL	Unauthenticated configuration disclosure at /cgi-bin/DownloadCfg/RouterCfm.jpg. Cleartext credentials and Wi-Fi keys exposed.
192.168.8.1	HARDENED	No exploitable vulnerabilities. Enforces session-aware 302 redirects and server-side token validation.

3. TARGET IDENTIFICATION

Target IP Address:	192.168.8.145
Device Manufacturer:	Tenda
Hardware Model:	F3 V2.0
Firmware Version:	Linux / v5.110.27.21
Active Web Server:	GoAhead-Webs

4. AUDIT METHODOLOGY

1. Automated Reconnaissance

Used the Nuclei vulnerability scanner with IoT/Router-specific templates to identify known exposure points.

2. Configuration Extraction	Manually queried sensitive paths (e.g., /cgi-bin/DownloadCfg/) to test for unauthenticated access.
3. Web Interface Analysis	Downloaded local client-side scripts (login.js) to reverse-engineer authentication logic, including encoding schemes and token requirements.
4. Authentication Simulation	Executed controlled HTTP POST requests via cURL to bypass frontend UI constraints and probe the backend.

5. SECURITY FINDINGS

CRITICAL

FINDING 1

Unauthenticated Configuration Exposure

Vulnerability ID:	CVE-2026-30140 (Incorrect Access Control)
Severity:	High / Critical
Exposed Endpoint:	http://192.168.8.145/cgi-bin/DownloadCfg/RouterCfm.jpg

The embedded web server fails to validate session authorisation or credentials before processing requests to the device backup script path. Although labelled with a cosmetic graphic extension (**.jpg**), the endpoint returns the **full cleartext operating configuration** of the deployment infrastructure.

Diagnostic Verification — HTTP Response Headers:

Status Code:	HTTP/1.0 200 OK
Content-Type:	config/conf
Content-Length:	15,229 bytes

Data Leaked via Exposed Endpoint:

- **Plaintext Identity Management:** Administrative account credentials stored via reversible encoding (Base64).
- **Wireless Pre-Shared Keys:** Cleartext WPA/WPA2 passphrases mapped to broadcasted SSIDs ("Zacs Valley 1013" / "Zacs Valley 1014").
- **Hardware Validation Data:** Static 8-digit WPS Device PINs and internal MAC address tables.

INFORMATIONAL

FINDING 2

Infrastructure Fingerprint & Protocol Anomalies

Services Flagged:

- Port 161/UDP — SNMPv3 Management Interface Engine
- Port 500/UDP — IKEv2 VPN Core Tunnelling Layer

Missing HTTP Security Headers:

- Strict-Transport-Security (HSTS)
- X-Frame-Options (Clickjacking defence)
- Content-Security-Policy (CSP)

6. DETAILED ANALYSIS

Target 192.168.8.145 — This device failed security best practices by exposing its configuration file without authentication. This enabled direct extraction of cleartext or weakly-encoded administrative credentials and Wi-Fi security keys.

Target 192.168.8.1 — This device demonstrated robust defence-in-depth. While analysis of login.js showed the password is transmitted using Base64 encoding, the server requires a valid session cookie and a dynamic CSRF token generated during the initial page load. Forged cURL requests were met with **401 Unauthorized** responses, confirming effective server-side handshake requirements.

7. REMEDIATION STRATEGY

1

Step 1 — Immediate Credential Rotation

Log into the administrative panel through legitimate means and immediately change the web root console password and all associated wireless network WPA/WPA2 pre-shared keys.

2

Step 2 — Disable Wi-Fi Protected Setup (WPS)

Turn off WPS functionality completely within the wireless settings panel. This neutralises the threat of the leaked static 8-digit hardware PIN being used to brute-force wireless security controls.

3

Step 3 — Harden Access Bounds

Verify that Remote Management (WAN-side access) is completely disabled. The web control interface must never be exposed from the public internet.

4

Step 4 — Infrastructure Isolation (VLAN)

If the legacy hardware cannot be patched by a manufacturer firmware upgrade to restrict directory authorisation, isolate the primary gateway subnet from untrusted endpoints via strict network-layer segregation.

8. CONCLUSION

The security gap between the two audited devices highlights that shared branding does not imply security parity. The **192.168.8.145** target is a primary example of *Broken Access Control* — a perennially top-ranked OWASP vulnerability — exposing the entire local network to credential theft and unauthorised reconfiguration.

Conversely, **192.168.8.1** demonstrates how modern firmware integrates session binding and request integrity checks to defeat standard exploitation techniques. Immediate remediation of the .145 device is strongly recommended before any further exposure is sustained.

This report was generated for internal security review purposes only. All testing was performed in a controlled local environment with appropriate authorisation.